

9장

소프트웨어 개발 보안 구축



440256

20.11, 필기 24.7, 23.5, 23.2, 22.7, 22.4, 21.3, 20.8, 20.6



175

소프트웨어 개발 보안 요소

(A)

소프트웨어 개발 보안 요소는 소프트웨어 개발에 있어 충족시켜야 할 요소 및 요건을 의미하며, 기밀성, 무결성, 가용성을 보안의 3대 요소라 한다.

필기 23.5, 22.7, 22.4, 21.3, 20.8

기밀성(Confidentiality)

- 시스템 내의 정보와 자원은 인가된 사용자에게만 접근이 허용된다.
- 정보가 전송 중에 노출되더라도 데이터를 읽을 수 없다.

필기 24.7, 23.5, 23.2, 22.7, 22.4, 21.3, 20.8, 20.6

무결성(Integrity)

시스템 내의 정보는 오직 인가된 사용자만 수정할 수 있다.

20.11, 필기 23.5, 22.7, 22.4, 21.3, 20.8

가용성(Availability)

인가받은 사용자는 시스템 내의 정보와 자원을 언제든지 사용할 수 있다.

인증(Authentication)

- 시스템 내의 정보와 자원을 사용하려는 사용자가 합법적인 사용자인지를 확인하는 모든 행위이다.
- 대표적 방법 : 패스워드, 인증용 카드, 지문 검사 등

부인 방지(NonRepudiation)

데이터를 송·수신한 자가 송·수신 사실을 부인할 수 없도록 송·수신 증거를 제공한다.

340329

20.7, 필기 24.2, 23.7, 21.8



176

SQL 삽입

(A)

- SQL 삽입(Injection)은 웹 응용 프로그램에 SQL을 삽입하여 내부 데이터베이스(DB) 서버의 데이터를 유출 및 변조하고, 관리자 인증을 우회하는 보안 약점이다.
- 동적 쿼리에 사용되는 입력 데이터에 예약어 및 특수문자가 입력되지 않게 필터링 되도록 설정하여 방지할 수 있다.

340336

필기 24.5, 21.5, 20.6



177

스택 가드

(B)

- 스택 가드(Stack Guard)는 널 포인터 역참조와 같이 주소가 저장되는 스택에서 발생하는 보안 약점을 막는 기술 중 하나이다.
- 메모리상에서 프로그램의 복귀 주소와 변수 사이에 특정 값을 저장한 후 그 값이 변경되었을 경우 오버플로우 상태로 판단하여 프로그램 실행을 중단함으로써 잘못된 복귀 주소의 호출을 막는다.

340337

필기 24.5, 24.2, 20.9, 20.6



178

접근 제어자

(B)

- 접근 제어자는 프로그래밍 언어에서 특정 개체를 선언할 때 외부로부터의 접근을 제한하기 위해 사용되는 예약어이다.
- 접근 제어자의 종류(접근 가능 : ○, 접근 불가능 : ×)

접근 제어자	클래스 내부	패키지 내부	하위 클래스	패키지 외부
필기 20.9, 20.6 Public	○	○	○	○
필기 20.6 Protected	○	○	○	×
필기 20.9 Default	○	○	×	×
필기 20.9, 20.6 Private	○	×	×	×

**179** 개인키 암호화 기법

- 개인키 암호화(Private Key Encryption) 기법은 동일한 키로 데이터를 암호화하고 복호화하는 암호화 기법이다.
- 대칭 암호 기법 또는 단일키 암호화 기법이라고도 한다.
- 암호화와 복호화 속도가 빠르다.
- 관리해야 할 키의 수가 많다.
- 개인키 암호화 기법의 종류에는 스트림 암호화 방식과 블록 암호화 방식이 있다.

스트림 암호화 방식	• 평문과 동일한 길이의 스트림을 생성하여 비트 단위로 암호화 하는 방식 • 종류 : LFSR, RC4, TKIP
블록 암호화 방식	• 한 번에 하나의 데이터 블록을 암호화 하는 방식 • 종류 : DES, SEED, AES, ARIA, IDEA, Skipjack

**180** IDEA

- IDEA(International Data Encryption Algorithm)는 스위스의 라이(Lai)와 메시(Messey)가 1990년에 개발한 PES를 개선한 알고리즘이다.
- 블록 크기는 64비트이고, 키 길이는 128비트이다.

**181** Skipjack

- Skipjack은 국가 안전 보장국(NSA)에서 개발한 암호화 알고리즘이다.
- 클리퍼 칩(Clipper Chip)이라는 IC 칩에 내장되어 있다.
- 블록 크기는 64비트이고, 키 길이는 80비트이다.
- 주로 음성 통신 장비에 삽입되어 음성 데이터를 암호화한다.

**182** DES

- DES(Data Encryption Standard)는 1975년 미국 NBS에서 발표한 개인키 암호화 알고리즘이다.
- 블록 크기는 64비트, 키 길이는 56비트이며 16회의 라운드를 수행한다.
- DES를 3번 적용하여 보안을 더욱 강화한 3DES(Triple DES)가 있다.

**183** AES

- AES(Advanced Encryption Standard)는 2001년 미국 표준 기술 연구소(NIST)에서 발표한 개인키 암호화 알고리즘이다.
- DES의 한계를 느낀 NIST에서 공모한 후 발표하였다.
- 블록 크기는 128비트이며, 키 길이에 따라 AES-128, AES-192, AES-256으로 분류된다.

**184** RSA

- RSA(Rivest Shamir Adleman)는 1978년 MIT의 라이베스트(Rivest), 샤미르(Shamir), 애들먼(Adelman)에 의해 제 안된 공개키 암호화 알고리즘이다.
- 큰 숫자를 소인수분해 하기 어렵다는 것에 기반하여 만들어졌다.

**185** TKIP

- TKIP(Temporal Key Integrity Protocol)는 기존의 무선 랜 보안 프로토콜인 WEP의 취약성을 보완한 데이터 보안 프로토콜이다.
- 암호 알고리즘의 입력 키 길이를 128비트로 늘리고 패킷당 키 할당, 키값 재설정 등의 키 관리 방식을 개선하였다.

**186 해시****(A)**

- 해시(Hash)는 임의의 길이의 **입력 데이터나 메시지**를 고정된 길이의 값이나 키로 변환하는 것을 의미한다.
- 해시 알고리즘을 해시 함수라고 부르며, 해시 함수로 변환된 값이나 키를 해시값 또는 해시키라고 부른다.
- 종류 : SHA 시리즈, HAVAL, MD4, MD5, N-NASH, SNEFRU 등

**187 MD5****(A)**

- MD5(Message Digest algorithm 5)는 1991년 R.Rivest가 MD4를 대체하기 위해 고안한 암호화 해시 함수이다.
- 블록 크기가 512비트이며, 키 길이는 128비트이다.

**188 인증****(B)**

- 인증(Authentication)은 다중 사용자 컴퓨터 시스템이나 네트워크 시스템에서 **로그인을 요청한 사용자**의 정보를 확인하고 접근 권한을 검증하는 보안 절차이다.
- 인증의 종류

종류	유형
지식 기반 인증 (Something You Know)	고정된 패스워드, 패스 프레이즈, 아이핀(i-Pin) 등
소유 기반 인증 (Something You Have)	신분증, 메모리 카드, 스마트 카드, OTP 등
생체 기반 인증 (Something You Are)	지문, 홍채/망막, 얼굴, 음성, 정맥 등
위치 기반 인증 (Somewhere You Are)	GPS, IP, 콜백 등
행위 기반 인증 (Something You Do)	서명, 동작 등

**189 OAuth****(A)**

- OAuth(Open Authorization)는 인터넷 애플리케이션에서 사용자 인증에 사용되는 표준 인증 방법으로, 공개 API(OpenAPI)로 구현되었다.
- 인터넷 사용자가 웹사이트나 애플리케이션에 비밀번호를 제공하지 않고 자신에게 접근 권한을 부여하여 사용할 수 있다.
- 2010년 IETF에서 1.0이 공식 표준안으로 발표되었다.

**190 VPN****(A)**

- VPN(Virtual Private Network, 가상 사설 통신망)은 인터넷 등 통신 사업자의 **공중 네트워크와 암호화 기술**을 이용하여 사용자가 마치 자신의 전용 회선을 사용하는 것처럼 해주는 보안 솔루션이다.
- SSL VPN : PC에 VPN Client 프로그램을 설치하여 VPN 서버에 접속하는 방식으로, 암호화를 위해 SSL 프로토콜을 사용함
- IPSec VPN : VPN 서버가 설치된 각각의 네트워크를 서로 연결하는 방식으로, 암호화를 위해 IPSec 프로토콜을 사용함

**191 SIEM****(A)**

- SIEM(Security Information and Event Management)은 다양한 장비에서 발생하는 **로그 및 보안 이벤트를 통합하여 관리**하는 빅 데이터 기반의 보안 솔루션이다.
- 방화벽, IDS, IPS, 웹 방화벽, VPN 등에서 발생한 로그 및 보안 이벤트를 통합하여 관리함으로써 비용 및 자원을 절약할 수 있다.
- 장기간의 로그 및 보안 이벤트를 수집 및 검색할 수 있는 빅데이터 기반의 통합 로그 수집 시스템이다.

440287



192 SSH

25.7, 23.4



- SSH(Secure SHell, 시큐어 셸)는 다른 컴퓨터에 원격으로 접속하여 작업을 수행할 수 있도록 다양한 기능을 지원하는 프로토콜 또는 이를 이용한 응용 프로그램이다.
- 데이터 암호화와 강력한 인증 방법으로 보안성이 낮은 네트워크에서도 안전하게 통신할 수 있다.
- 키(key)를 통한 인증 방법을 사용하려면 사전에 클라이언트의 공개키를 서버에 등록해야 한다.
- 기본적으로는 22번 포트를 사용한다.

340362



193 AAA(=3A)

21.10



- AAA는 다음 3가지 기능을 기반으로 사용자의 컴퓨터 자원 접근에 대한 처리와 서비스를 제공하는 기반 구조(Infrastructure) 또는 규격을 의미한다.
- 인증(Authentication) : 접근하는 사용자의 신원을 검증하는 기능
- 인가(Authorization) : 신원이 검증된 사용자에게 특정된 권한과 서비스를 허용하는 기능
- 과금(Accounting) : 사용자가 어떤 종류의 서비스를 이용했고, 얼마만큼의 자원을 사용했는지 기록 및 보관하는 기능

340363



194 정보보호 관리 체계

22.5



- 정보보호 관리 체계(ISMS; Information Security Management System)는 정보 자산을 안전하게 보호하기 위한 보호 절차와 대책을 의미한다.
- 조직에 맞는 정보보호 정책을 수립하고, 위협에 상시 대응하는 여러 보안 대책을 통합 관리·운용한다.
- 우리나라에서는 정보보호 관리 체계를 평가하고 인증하는 사업을 한국인터넷진흥원(KISA)에서 운영하고 있다.

340552



195 SYN Flooding

25.7



- TCP(Transmission Control Protocol)는 신뢰성 있는 전송을 위해 3-wayhandshake를 거친 후에 데이터를 전송하게 되는데, SYN Flooding은 공격자가 가상의 클라이언트로 위장하여 3-way-handshake 과정을 의도적으로 중단시킴으로써 공격 대상인 서버가 대기 상태에 놓여 정상적인 서비스를 수행하지 못하게 하는 공격 방법이다.
- 3-way-handshake
 - 신뢰성 있는 연결을 위해 송신지와 수신지 간의 통신에 앞서 3단계에 걸친 확인 작업을 수행한 후 통신을 수행한다.
 - 1단계 : 송신지에서 수신지로 'SYN' 패킷을 전송
 - 2단계 : 수신지에서 송신지로 'SYN + ACK' 패킷을 전송
 - 3단계 : 송신지에서 수신지로 'ACK' 패킷을 전송

340366



196 SMURFING

24.10, 필기 24.2, 23.5, 20.6



- SMURFING(스머핑)은 IP나 ICMP의 특성을 악용하여 엄청난 양의 데이터를 한 사이트에 집중적으로 보냄으로써 네트워크를 불능 상태로 만드는 공격 방법이다.
- SMURFING 공격을 무력화하는 방법 중 하나는 각 네트워크 라우터에서 브로드캐스트 주소를 사용할 수 없게 미리 설정해 놓는 것이다.

340369



197 LAND Attack

20.5, 필기 24.2, 23.2



LAND Attack(Local Area Network Denial Attack)은 패킷을 전송할 때 송신 IP 주소와 수신 IP 주소를 모두 공격 대상의 IP 주소로 하여 공격 대상에게 전송하는 것으로, 이 패킷을 받은 공격 대상은 송신 IP 주소가 자신이므로 자신에게 응답을 수행하게 되는데, 이러한 패킷이 계속해서 전송될 경우 자신에 대해 무한히 응답하게 하는 공격 방법이다.

340513

25.4



198 스케어웨어



스케어웨어(Scareware)는 사용자에게 컴퓨터가 바이러스에 감염되었다고 속이거나 보안 위험이 있다고 거짓 경고 메시지를 보내어 불안감을 조성한 후 문제 해결을 명목으로 불필요한 소프트웨어 구매를 유도하는 악성 소프트웨어이다.

340372

25.4, 21.4, 필기 24.7, 22.7, 21.3



199 세션 하이재킹



- 세션 하이재킹(Session Hijacking)은 상호 인증 과정을 거친 후 접속해 있는 서버와 서로 접속되어 클라이언트 사이의 세션 정보를 가로채는 공격 기법으로, 접속을 위한 인증 정보 없이도 가로챈 세션을 이용해 공격자가 원래의 클라이언트인 것처럼 위장하여 서버의 자원이나 데이터를 무단으로 사용한다.
- TCP 3-Way-Handshake 과정에 끼어들어서 클라이언트와 서버 간의 동기화된 시퀀스 번호를 가로채 서버에 무단으로 접근하는 TCP 세션 하이재킹이 대표적인 예이다.

340373

21.10



200 ARP 스푸핑



ARP 스푸핑(ARP Spoofing)은 ARP의 취약점을 이용한 공격 기법으로, 자신의 물리적 주소(MAC)를 공격 대상의 것으로 변조하여 공격 대상에게 도달해야 하는 데이터 패킷을 가로채거나 방해하는 기법이다.

※ ARP(Address Resolution Protocol) : 호스트의 IP 주소를 호스트와 연결된 네트워크 접속 장치의 물리적 주소(MAC Address)로 변환해주는 프로토콜

440300

22.10



201 사회 공학



사회 공학(Social Engineering)은 컴퓨터 보안에 있어서, 인간 상호 작용의 깊은 신뢰를 바탕으로 사람들을 속여 정상 보안 절차를 깨트리기 위한 비기술적 시스템 침입 수단이다.

440301

22.10



202 다크 데이터



다크 데이터(Dark Data)는 특정 목적을 가지고 데이터를 수집하였으나, 이후 활용되지 않고 저장만 되어 있는 대량의 데이터를 의미한다.

440302

22.10



203 타이포스쿼팅



- 타이포스쿼팅(Typosquatting)은 네티즌들이 사이트에 접속할 때 주소를 잘못 입력하거나 철자를 빠뜨리는 실수를 이용하기 위해 이와 유사한 유명 도메인을 미리 등록하는 것이다.
- URL 하이재킹(Hijacking)이라고도 한다.

340374

20.11, 필기 23.2



204 스니핑



스니핑(Sniffing)은 네트워크의 중간에서 남의 패킷 정보를 도청하는 해킹 유형의 하나로, 수동적 공격에 해당한다.



205 워터링 홀

(A)

- 워터링 홀(Watering Hole)은 목표 대상이 자주 방문하는 웹 사이트를 사전에 감염시켜 대상이 해당 사이트에 방문했을 때 악성 코드에 감염되게 하는 웹 기반 공격이다.
- 감염된 PC를 기반으로 대상이 속한 조직의 중요 시스템에 접근하거나 불능으로 만드는 등의 영향력을 행사할 수 있다.



206 키로거 공격

(C)

키로거 공격(Key Logger Attack)은 컴퓨터 사용자의 키보드 움직임을 탐지해 ID, 패스워드, 계좌번호, 카드번호 등과 같은 개인의 중요한 정보를 몰래 빼가는 해킹 공격이다.



207 랜섬웨어

(B)

랜섬웨어(Ransomware)는 인터넷 사용자의 컴퓨터에 잠입해 내부 문서나 파일 등을 암호화해 사용자가 열지 못하게 하는 프로그램으로, 암호 해독용 프로그램의 전달을 조건으로 사용자에게 돈을 요구하기도 한다.



208 백도어

(C)

- 백도어(Back Door, Trap Door)는 시스템 설계자가 서비스 기술자나 유지 보수 프로그램 작성자의 액세스 편의를 위해 시스템 보안을 제거하여 만들어놓은 비밀 통로로, 컴퓨터 범죄에 악용되기도 한다.
- 백도어 탐지 방법 : 무결성 검사, 열린 포트 확인, 로그 분석, SetUID 파일 검사 등



209 기타 정보 보안 관련 용어 1

(A)

24.4

Rootkit

- 시스템에 침입한 후 침입 사실을 숨긴 채 백도어, 트로이목마를 설치하고, 원격 접근, 내부 사용 흔적 삭제, 관리자 권한 획득 등 주로 불법적인 해킹에 사용되는 기능들을 제공하는 프로그램들의 모음이다.
- 컴퓨터의 운영체제에서 실행 파일과 실행 중인 프로세스를 숨김으로써 운영체제 검사 및 백신 프로그램의 탐지를 피할 수 있다.

24.4

APT(Advanced Persistent Threats, 지능형 지속 위협)

다양한 IT 기술과 방식들을 이용해 조직적으로 특정 기업이나 조직 네트워크에 침투해 활동 거점을 마련한 뒤 때를 기다리면서 보안을 무력화시키고 정보를 수집한 다음 외부로 빼돌리는 형태의 공격이다.

Ping of Death(죽음의 핑)

Ping 명령을 전송할 때 패킷의 크기를 인터넷 프로토콜 허용 범위 이상으로 전송하여 공격 대상의 네트워크를 마비시키는 서비스 거부 공격 방법이다.

큐싱(Qshing)

QR코드(Quick Response Code)를 통해 악성 앱의 다운로드를 유도하거나 악성 프로그램을 설치하도록 하는 금융사기 기법의 하나로, QR코드와 개인정보 및 금융정보를 낚는다(Fishing)는 의미의 합성 신조어이다.

스미싱(Smishing)

문자 메시지(SMS)를 이용해 사용자의 개인 신용 정보를 빼내는 수법이다.

스피어 피싱(Spear Phishing)

사회 공학의 한 기법으로, 특정 대상을 선정한 후 그 대상에게 일반적인 이메일로 위장한 메일을 지속적으로 발송하여, 발송 메일의 본문 링크나 첨부된 파일을 클릭하도록 유도해 사용자의 개인 정보를 탈취하는 공격이다.



210 기타 정보 보안 관련 용어 2 A

좀비(Zombie) PC

악성코드에 감염되어 다른 프로그램이나 컴퓨터를 조종하도록 만들어진 컴퓨터로, C&C(Command & Control) 서버의 제어를 받아 주로 DDoS 공격 등에 이용된다.

C&C 서버

해커가 원격지에서 감염된 좀비 PC에 명령을 내리고 악성코드를 제어하기 위한 용도로 사용하는 서버를 말한다.

봇넷(Botnet)

악성 프로그램에 감염되어 악의적인 의도로 사용될 수 있는 다수의 컴퓨터들이 네트워크로 연결된 형태를 말한다.

제로 데이 공격(Zero Day Attack)

보안 취약점이 발견되었을 때 발견된 취약점의 존재 자체가 널리 공표되기도 전에 해당 취약점을 통하여 이루어지는 보안 공격으로, 공격의 신속성을 의미한다.

23.4

트로이 목마(Trojan Horse)

정상적인 기능을 하는 프로그램으로 위장하여 프로그램 내에 숨어 있다가 해당 프로그램이 동작할 때 활성화되어 부작용을 일으키지만 자기 복제 능력은 없다.

CC(Common Criteria) 인증

국가마다 서로 다른 정보보호시스템 평가기준을 연동하고 평가결과를 상호 인증하기 위해 제정된 정보보안 평가기준으로, ISO/IEC 15408에 등록된 국제 표준이다.

멀버타이징(Malvertising)

악성 소프트웨어를 뜻하는 멀웨어(Malware)와 광고(Advertising)의 합성어로, 온라인 광고를 통해 악성코드를 유포시키는 행위를 말한다.

정보공유분석센터(ISAC; Information Sharing & Analysis Center)

취약점 및 침해요인과 그 대응방안에 관한 정보를 제공하며, 침해사고가 발생하는 경우 실시간 경보·분석체계를 운영하고, 금융·통신 등 분야별 정보통신기반시설을 보호하기 위한 업무를 수행하는 곳이다.

침입 탐지 시스템(IDS; Intrusion Detection System)

컴퓨터 시스템의 비정상적인 사용, 오용, 남용 등을 실시간으로 탐지하는 시스템이다.

데이터 디들링(Data Diddling)

처리할 자료를 다른 자료와 바꿔서 처리하는 것으로, 입력값이나 출력값을 부정한 의도로 수정하여 잘못된 결과가 나오도록 유도하는 방식이다.

비트로커(BitLocker)

Windows 7부터 지원되기 시작한 Windows 전용의 볼륨 암호화 기능으로, TPM(Trusted Platform Module)과 AES-128 알고리즘을 사용한다.

공급망 공격(Supply Chain Attack)

소프트웨어 공급망에 침투하여 악성코드를 배포하는 공격으로, SW 빌드 및 배포 과정에 악성코드를 삽입하여 이용자들을 공격한다.

23.4

바이러스(Virus)

컴퓨터의 정상적인 작동을 방해하기 위해 운영체제나 저장된 데이터에 손상을 입히는 프로그램으로, 자신을 복제할 수 있고, 다른 프로그램을 감염시킬 수 있다.

23.4, 필기 24.5, 22.7, 22.4

웜(Worm)

네트워크를 통해 연속적으로 자신을 복제하여 시스템의 부하를 높임으로써 결국 시스템을 다운시키는 바이러스의 일종으로, 분산 서비스 거부 공격, 버퍼 오버플로 공격, 슬래머 등이 웜 공격의 한 형태이다.